

Rapport d'Audit : Scan et Analyse de Sécurité d'un Système Windows

1. Introduction et Objectifs

L'objectif de cette mission était de simuler la démarche d'un attaquant ou d'un auditeur pour identifier les services exposés sur une machine Windows spécifique. L'analyse s'est concentrée sur l'identification des vecteurs d'attaque courants en entreprise, notamment les protocoles de partage de fichiers et d'accès à distance.

2. Phase de Reconnaissance et Scan de Ports

La première étape a consisté à identifier les ports ouverts sur la cible via un scan furtif.

- **Commande utilisée :** `nmap -sS 192.168.56.20`
- **Observations :** Le scan a révélé plusieurs services critiques actifs : le port 135 (RPC), le port 139 (NetBIOS), le port 445 (SMB) et le port 3389 (RDP).

```
(tsafack@Tsafack)-[~]
$ nmap -sS 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 16:40 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00040s latency).
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
5357/tcp   open  wsddapi
49152/tcp  open  unknown
49153/tcp  open  unknown
49154/tcp  open  unknown
49155/tcp  open  unknown
49156/tcp  open  unknown
49157/tcp  open  unknown
MAC Address: 08:00:27:8C:2B:F4 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.99 seconds

(tsafack@Tsafack)-[~]
$
```

3. Identification Précise des Services

Une fois les ports identifiés, une analyse de version a été effectuée pour déterminer si les services tournant sur ces ports présentent des obsolescences.

- **Commande utilisée :** `nmap -sV 192.168.56.20`
- **Interprétation :** Cette étape est cruciale car elle permet d'affiner l'attaque en fonction de la version spécifique du système d'exploitation Windows détecté.

```
(tsafack@Tsafack)-[~]
$ nmap -sV 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 16:42 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00044s latency).
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
5357/tcp   open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49152/tcp  open  msrpc        Microsoft Windows RPC
49153/tcp  open  msrpc        Microsoft Windows RPC
49154/tcp  open  msrpc        Microsoft Windows RPC
49155/tcp  open  msrpc        Microsoft Windows RPC
49156/tcp  open  msrpc        Microsoft Windows RPC
49157/tcp  open  msrpc        Microsoft Windows RPC
MAC Address: 08:00:27:8C:2B:F4 (Oracle VirtualBox virtual NIC)
Service Info: Host: WILLY-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 61.36 seconds
```

4. Analyse du Protocole SMB et Détection de Vulnérabilités

Le service SMB (port 445) est souvent le maillon faible des systèmes Windows. Nous avons utilisé des scripts NSE (Nmap Scripting Engine) pour extraire des informations système et tester la vulnérabilité aux attaques majeures.

- **Scan de découverte :** `nmap -p 445 --script smb-os-discovery 192.168.56.20`

```
(tsafack@Tsafack)-[~]
$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 16:47 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00041s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds
MAC Address: 08:00:27:8C:2B:F4 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-os-discovery:
|   OS: Windows 7 Professional N 7600 (Windows 7 Professional N 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::-:professional
|   Computer name: willy-PC
|   NetBIOS computer name: WILLY-PC\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-16T15:47:33+02:00

Nmap done: 1 IP address (1 host up) scanned in 5.02 seconds
```

- **Scan de vulnérabilité :** `nmap --script smb-vuln* -p 445 192.168.56.20`

```
(tsafack@Tsafack)-[~]
$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 16:47 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00041s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds
MAC Address: 08:00:27:8C:2B:F4 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-os-discovery:
|   OS: Windows 7 Professional N 7600 (Windows 7 Professional N 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::-:professional
|   Computer name: willy-PC
|   NetBIOS computer name: WILLY-PC\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-16T15:47:33+02:00

Nmap done: 1 IP address (1 host up) scanned in 5.02 seconds
```

Analyse des risques : Si le système est vulnérable (par exemple à *EternalBlue*), un attaquant peut prendre le contrôle total de la machine à distance sans authentification, comme ce fut le cas lors de l'épidémie du ransomware WannaCry.

5. Audit du Service de Bureau à Distance (RDP)

Le port 3389 a été analysé pour vérifier le niveau de chiffrement et la robustesse de la configuration de l'accès à distance.

- **Commande utilisée :** `nmap -p 3389 --script rdp-enum-encryption 192.168.56.20`
- **Constat :** Un service RDP mal configuré ou utilisant un chiffrement faible expose l'entreprise à des attaques de type "Man-in-the-Middle" ou à du brute-force sur les identifiants de connexion.

```
(tsafack@Tsafack)-[~]
$ nmap -p 3389 --script rdp-enum-encryption 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 16:53 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00046s latency).

PORT      STATE SERVICE
3389/tcp    closed ms-wbt-server
MAC Address: 08:00:27:8C:2B:F4 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.87 seconds
```

6. Analyse Globale et Recommandations (Synthèse)

À la suite de cet audit, voici l'évaluation de la situation et les mesures correctives préconisées :

Identification des services critiques

Les services **SMB (445)** et **RDP (3389)** sont les points les plus sensibles identifiés sur cette machine. Ils représentent des portes d'entrée directes vers le système de fichiers et le contrôle de l'interface utilisateur.

Détermination des risques

1. **Exploitation de faille système** : Risque d'exécution de code à distance via des vulnérabilités SMB non patchées.
2. **Infiltration par Brute Force** : Le service RDP peut être ciblé par des tentatives de connexion massives pour deviner les mots de passe.
3. **Mouvement latéral** : Une fois le poste compromis, un attaquant pourrait utiliser ces services pour rebondir sur d'autres machines du réseau.

Mesures de sécurisation proposées

Pour renforcer la sécurité de l'hôte, nous recommandons les actions suivantes :

- **Désactiver SMBv1** : Ce protocole est obsolète et hautement vulnérable. Il doit être remplacé par SMBv2 ou v3.
- **Restreindre l'accès RDP** : Limiter l'accès au port 3389 via le pare-feu (n'autoriser que certaines IP) et imposer une authentification forte (MFA).
- **Activation du Pare-feu Windows** : S'assurer que le pare-feu est actif et configuré pour bloquer tout flux entrant non nécessaire.
- **Politique de mots de passe** : Appliquer une politique de complexité stricte pour limiter l'efficacité des attaques par dictionnaire.
- **Mises à jour** : Installer les derniers correctifs de sécurité Windows pour combler les failles testées par les scripts Nmap.